



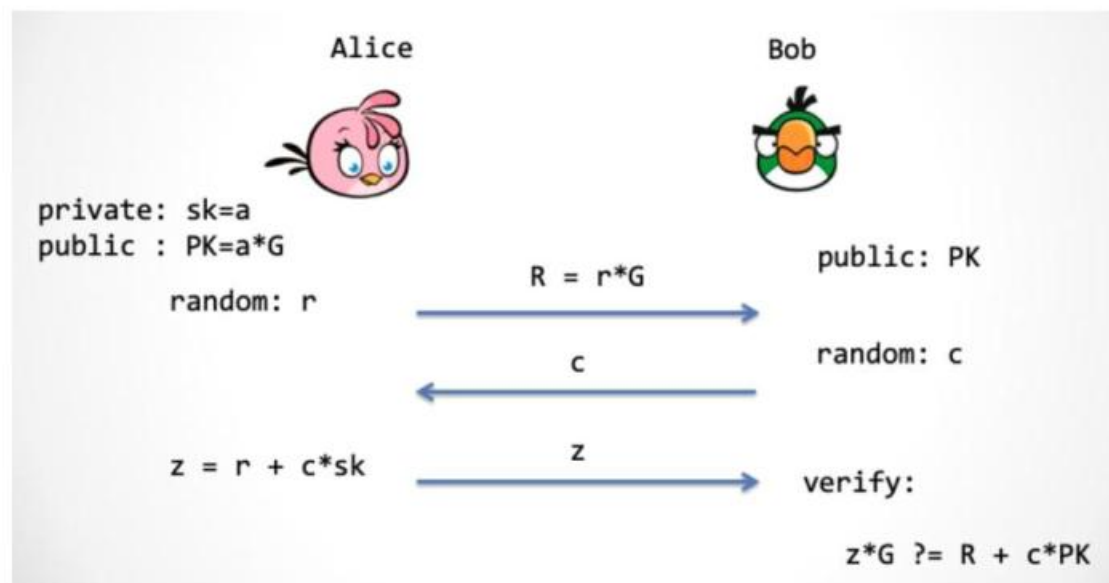
密码协议

第二次作业讲解

2026年5月7日

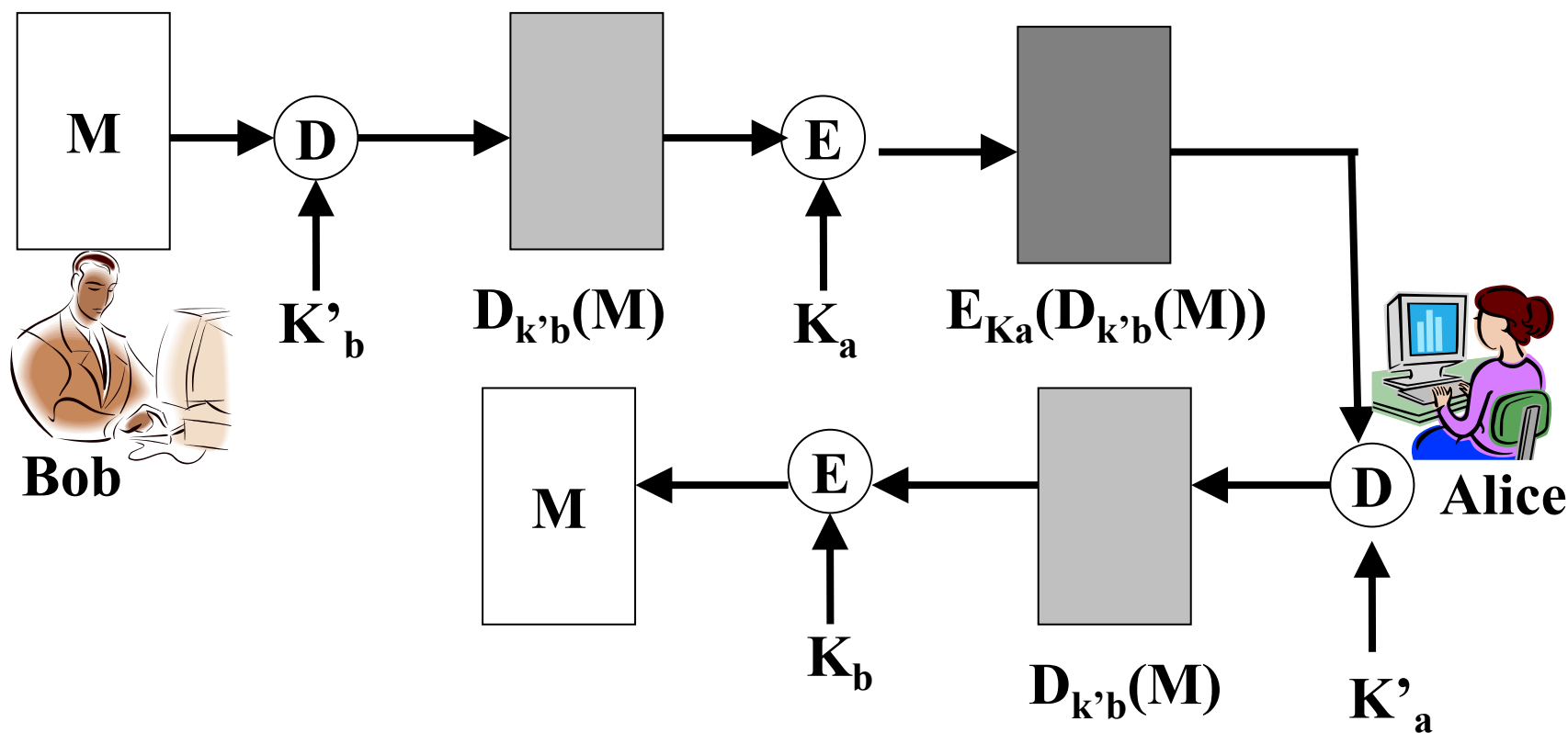
第二次作业

1. 在通信中，为了保证通信的机密性与认证性，需要使用加密和签名的技术。请分析在实践中对消息“先签名后加密”更好，还是“先加密后签名”更好？各有什么优缺点？
2. 量子计算机对于对称密码算法和非对称密码算法会有哪些影响？它对于口令、口令密码协议是否有影响？请说明理由。
3. 交互式 schnorr 零知识证明协议在什么情况下证明者的私钥 sk 能被敌手计算出来？思考并阐述 Fiat-Shamir 变换将交互式零知识证明转换成非交互式零知识证明的原理。



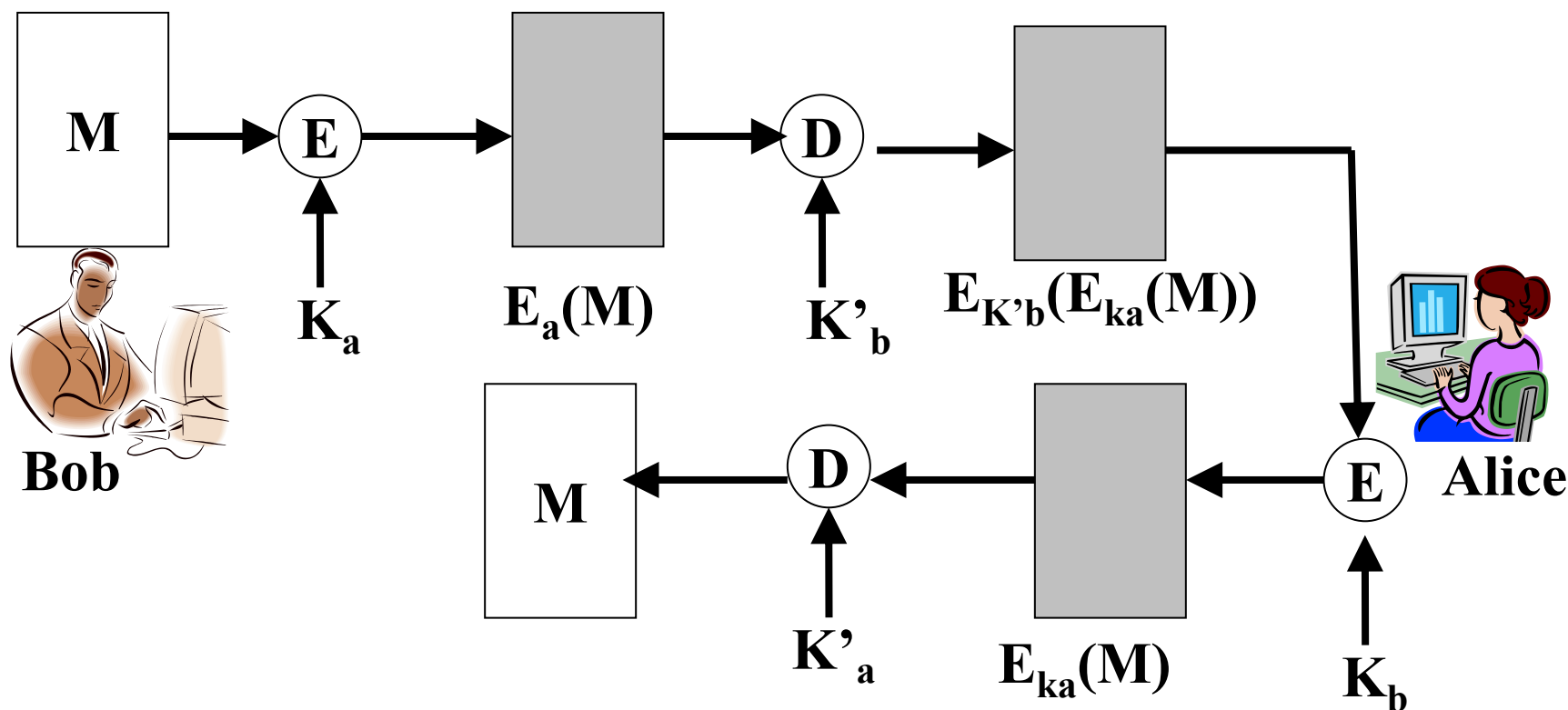
先签名后加密

- **优点：**可以提供机密性和认证性，只有知道消息明文才能够签名；更加常用的一种做法。
- **缺点：**无法保证消息公开验证性，只有拥有接收方私钥的人才能验证消息真实性和完整性；增加加密的工作量，影响效率。



先加密后签名

- **优点：**保证消息公开验证性；只加密明文，效率更高。
- **缺点：**提供机密性，不提供认证性；第三方攻击者可以篡改签名，接收方无法确认签名是否来自消息创建者。（攻击成功前提是接收方仅使用中间人的公钥验证签名，先加密后签名并非一定不安全，例如可以在消息明文中指示发送方的身份）



On the Security of Joint Signature and Encryption

Jee Hea An*

Yevgeniy Dodis[†]

Tal Rabin[‡]

June 17, 2002

Abstract

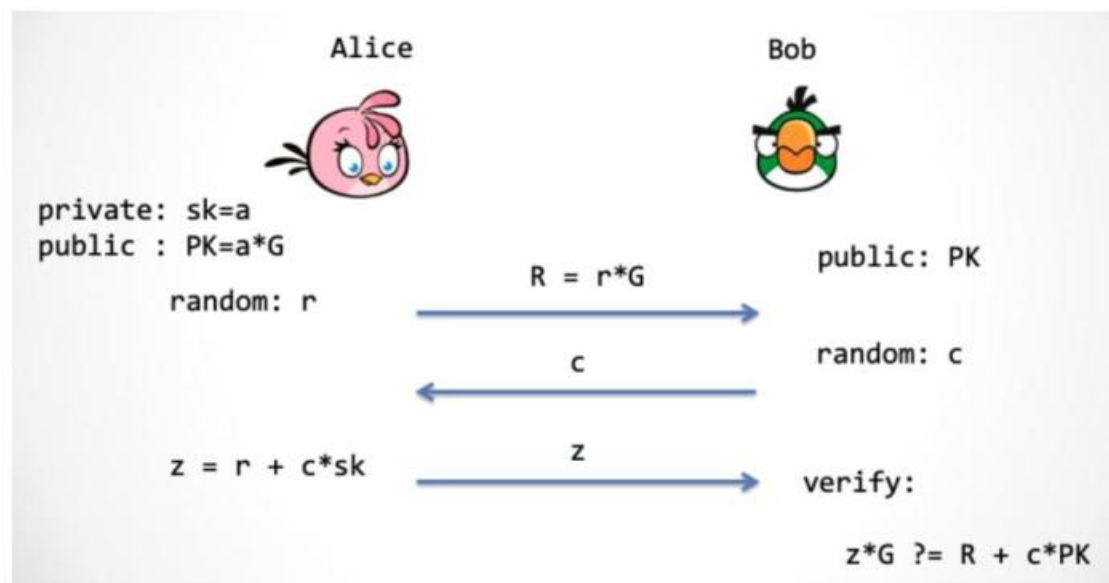
We formally study the notion of a joint signature and encryption in the public-key setting. We refer to this primitive as *signcryption*, adapting the terminology of [36]. We present two definitions for the security of signcryption depending on whether the adversary is an outsider or a legal user of the system. We then examine generic sequential composition methods of building signcryption from a signature and an encryption scheme. In particular, we show that the classical “encrypt-then-sign” ($\mathcal{EtS}$) and “sign-then-encrypt” ($\mathcal{StE}$) methods — when modeled “properly” — are both *secure* composition methods in the public-key setting.

We also present a new composition method which we call “commit-then-encrypt-and-sign” ($\mathcal{CtE\&S}$). Unlike the generic sequential composition methods, $\mathcal{CtE\&S}$ applies the expensive signature and encryption operations *in parallel*, which could imply a gain in efficiency over the $\mathcal{StE}$ and $\mathcal{EtS}$ schemes. We also show that the new $\mathcal{CtE\&S}$ method elegantly combines with the recent “hash-sign-switch” technique of [31], leading to efficient *on-line/off-line* signcryption.

Finally and of independent interest, we discuss the *definitional* inadequacy of the standard notion of chosen ciphertext (CCA2) security. We suggest a natural and very slight relaxation of CCA2-security, which we call generalized CCA2-security (gCCA2). We show that gCCA2-security suffices for all known uses of CCA2-secure encryption, while no longer suffering from the definitional shortcomings of the latter.

第二次作业

1. 在通信中，为了保证通信的机密性与认证性，需要使用加密和签名的技术。请分析在实践中对消息“先签名后加密”更好，还是“先加密后签名”更好？各有什么优缺点？
2. 量子计算机对于对称密码算法和非对称密码算法会有哪些影响？它对于口令、口令密码协议是否有影响？请说明理由。
3. 交互式 schnorr 零知识证明协议在什么情况下证明者的私钥 sk 能被敌手计算出来？思考并阐述 Fiat-Shamir 变换将交互式零知识证明转换成非交互式零知识证明的原理。



对称密码算法： Grover量子搜索算法会降低高级加密标准(AES)等对称加密系统的安全性，时间复杂度为 $O(\sqrt{N})$ ，50%削弱对称密码算法的强度。

非对称密码算法： 安全性建立在离散对数、整数分解等传统困难问题上， Shor算法可以在多项式时间内解决任意合数的质因数分解， 破解RSA和Diffie-Hellman等公钥密码系统。量子计算机颠覆非对称密码算法的安全性。

口令： 量子计算机对密码算法有影响，对密钥无影响；口令是低熵密钥，攻击口令依然需要猜测攻击。

口令密码协议： 基于非对称密码算法的协议不再安全？

Table 1: Security Comparison						
Type of Attack	Symmetric Encryption			Public Key Encryption		
		Key Length	Bits of Security		Key Length	Bits of Security
Classical Computers	AES-128	128	128	RSA-2048	2048	112
	AES-256	256	256	RSA-15360	15,360	256
Quantum Computers	AES-128	128	64	RSA-2048	2048	25
	AES-256	256	128	RSA-15360	15,360	31

--<https://techbeacon.com/security/waiting-quantum-computing-why-encryption-has-nothing-worry-about>

The “quantum annoying” property of password-authenticated key exchange protocols

Edward Eaton^{1,2} and Douglas Stebila¹

¹ University of Waterloo, Waterloo, Canada,
eeaton@uwaterloo.ca, dstebila@uwaterloo.ca

² ISARA Corporation, Waterloo, Canada

Abstract. During the Crypto Forum Research Group (CFRG)’s standardization of password-authenticated key exchange (PAKE) protocols, a novel property emerged: a PAKE scheme is said to be “quantum-annoying” if a quantum computer *can* compromise the security of the scheme, but only by solving one discrete logarithm for each guess of a password. Considering that early quantum computers will likely take quite long to solve even a single discrete logarithm, a quantum-annoying PAKE, combined with a large password space, could delay the need for a post-quantum replacement by years, or even decades.

In this paper, we make the first steps towards formalizing the quantum-

Current estimates for how long quantum computers will take to solve a cryptographically relevant discrete logarithm problem vary depending on factors such as the error rate and the number of coherent qubits available. In a recent analysis, Gheorghiu and Mosca [6] estimated that, to solve a discrete logarithm on the NIST P-256 elliptic curve, it would take one day on a quantum computer with 2^{26} physical qubits, or a 6 minutes on a 2^{34} -physical-qubit quantum computer. With early quantum computers taking hours or days, and even mature ones taking minutes for a single discrete logarithm, brute-forcing passwords in a quantum-annoying scheme is probably infeasible for all but the most dedicated and resourceful adversary. For well-chosen passwords from high entropy spaces, considerable quantum resources would be needed to compromise a single password. In such a scenario it would of course be best to replace PAKEs with a suitable post-quantum primitive, but quantum annoyingness is still appealing.

Making an Asymmetric PAKE Quantum-Annoying by Hiding Group Elements[‡]

Marcel Tiepelt¹[0000-0002-3389-208X], Edward Eaton², and Douglas Stebila³[0000-0001-9443-3170]

¹ KASTEL, Karlsruhe, Germany, marcel.tiepelt@kit.edu

² National Research Council Canada, Ottawa, Ontario, Canada

³ University of Waterloo, Waterloo, Ontario, Canada, dstebila@uwaterloo.ca

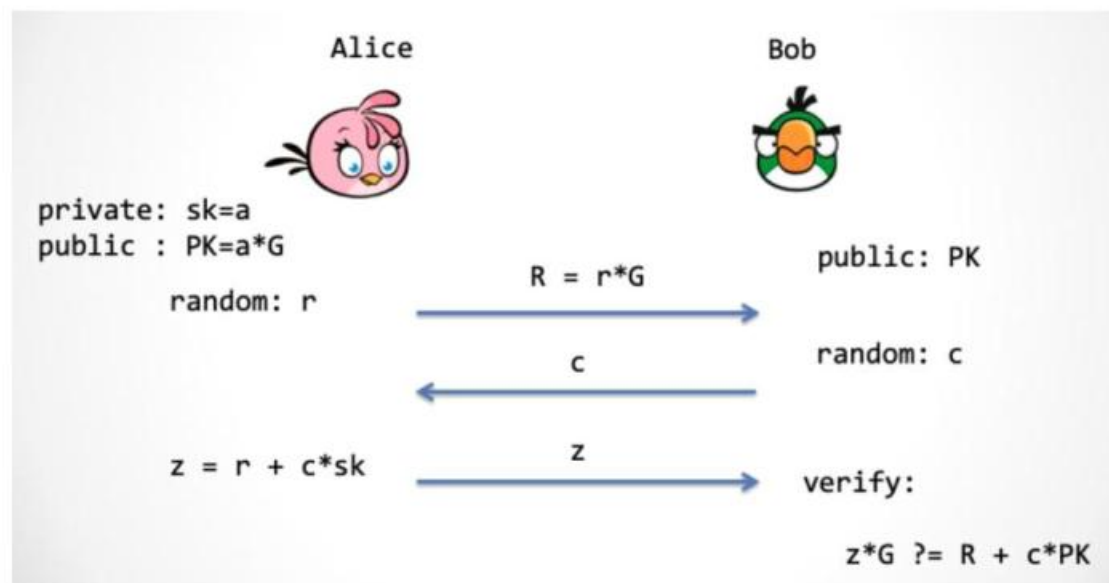
Abstract The KHAPE-HMQV protocol is a state-of-the-art highly efficient asymmetric password-authenticated key exchange protocol that provides several desirable security properties, but has the drawback of being vulnerable to quantum adversaries due to its reliance on discrete logarithm-based building blocks: solving a single discrete logarithm allows the attacker to perform an offline dictionary attack and recover the password. We show how to modify KHAPE-HMQV to make the protocol *quantum-annoying*: a classical adversary who has the additional ability to solve discrete logarithms can only break the protocol by solving a discrete logarithm for each guess of the password. While not fully resistant

在NIST P-256椭圆曲线上解一个离散对数，中等规模的量子计算机可能需要几分钟到一天。因此，在一个“anqutum annoying”的协议中，暴力破解口令对于大多数攻击者是不可行的。



第二次作业

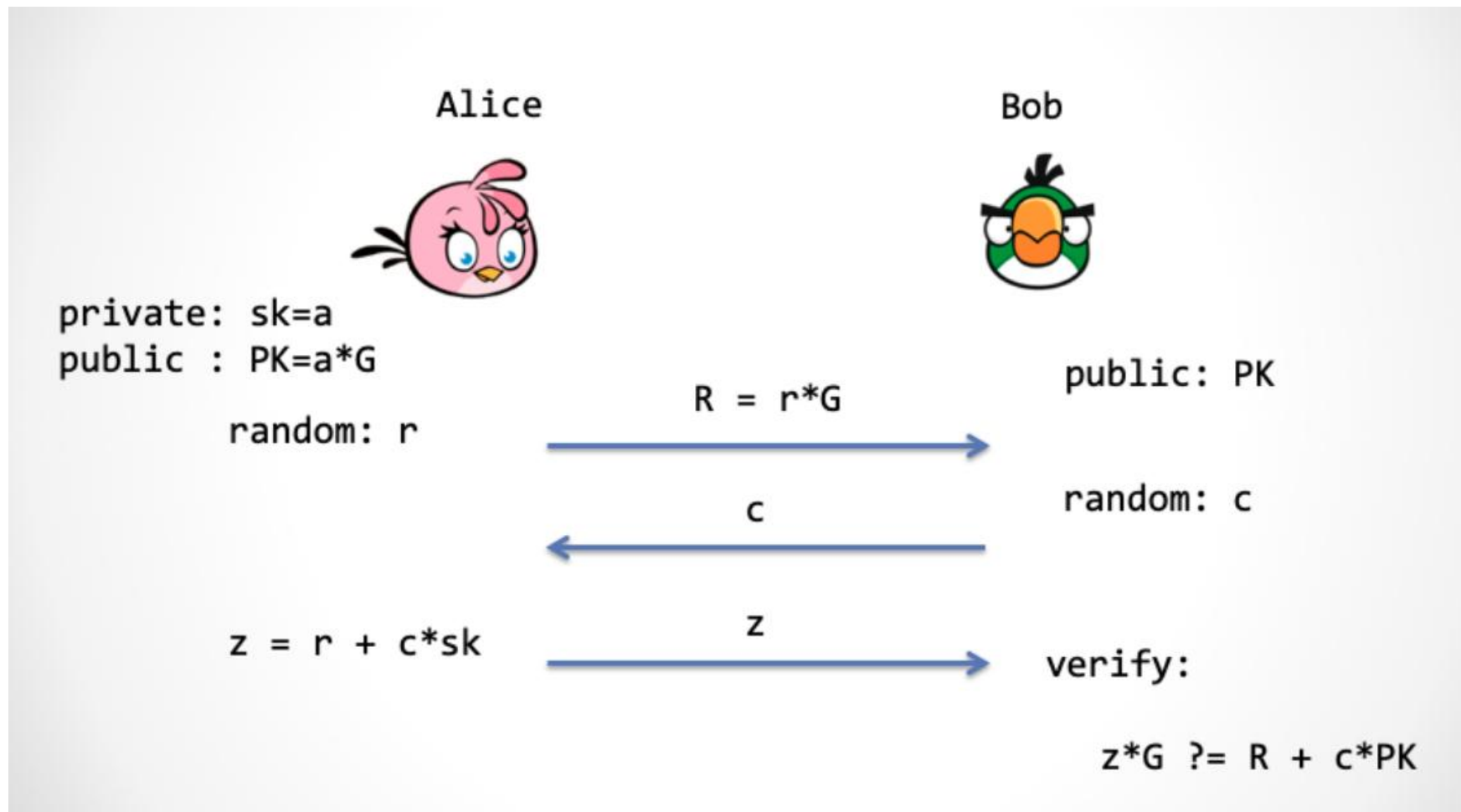
1. 在通信中，为了保证通信的机密性与认证性，需要使用加密和签名的技术。请分析在实践中对消息“先签名后加密”更好，还是“先加密后签名”更好？各有什么优缺点？
2. 量子计算机对于对称密码算法和非对称密码算法会有哪些影响？它对于口令、口令密码协议是否有影响？请说明理由。
3. 交互式 schnorr 零知识证明协议在什么情况下证明者的私钥 sk 能被敌手计算出来？思考并阐述 Fiat-Shamir 变换将交互式零知识证明转换成非交互式零知识证明的原理。



两次运行Schnorr协议重用相同的 r ，证明者一旦出现“技术失误”（多次使用相同承诺）会泄露 sk

$$z_1 = r + c_1 * sk$$

$$z_2 = r + c_2 * sk, \text{ 可以重建出密钥 } sk = \frac{z_1 - z_2}{c_1 - c_2}。$$



Fiat-Shamir变换原理：通过随机数挑战是交互式零知识证明的信任根基。在非交互式Schnorr认证方案中，Hash函数担负起了挑战者的角色，被建模成随机预言机(ROM)。 $c = \text{Hash}(PK, R)$ ，只要 r 是随机的， c 也是随机的（ROM面对一个新的查询，会返回一个随机输出）。

